Cybersecurity Risk Assessment and NIST CSF Gap Analysis for University IT Infrastructure

Ravintharan Sanjiv

Aspiring Cybersecurity / GRC Analyst

NIST Cybersecurity Framework

March 2026

This report is a simulated cybersecurity assessment conducted for educational purposes and does not represent a real organization.

Summary

This report presents the results of a cybersecurity risk assessment conducted for a simulated university IT environment using the **National Institute of Standards and Technology Cybersecurity Framework (NIST CSF)** as the primary evaluation model. The objective of this assessment was to identify cybersecurity risks affecting critical organizational systems, evaluate the effectiveness of existing security controls, and identify areas where improvements are required to strengthen the organization's overall cybersecurity posture.

The assessment began with the development of an asset inventory that identified key systems supporting the organization's operations, including the Student Information System, Learning Management System, email services, financial management systems, campus network infrastructure, and file storage servers. A structured risk assessment was then performed to identify potential threats to these assets and evaluate each risk based on likelihood and potential impact.

The analysis identified several high-priority cybersecurity risks. The most critical risks include **phishing attacks targeting the email system** and **credential theft affecting authentication services**, both of which received the highest risk scores due to their high likelihood and potential impact. Additional high-level risks include ransomware infections on file servers, unauthorized access to sensitive databases, and potential data breaches affecting financial systems.

A cybersecurity maturity assessment based on the NIST CSF functions indicated that the organization currently operates at an **early stage of cybersecurity maturity with an overall score of approximately 1.8 out of 5**. The lowest maturity levels were observed within the **Detect and Respond functions**, indicating limited monitoring capabilities and the absence of a formal incident response framework.

Based on these findings, several key recommendations are proposed. These include implementing **multi-factor authentication (MFA)**, establishing a formal **incident response plan**, deploying centralized **security monitoring capabilities**, and conducting regular **security awareness training** to reduce the likelihood of user-based attacks.

Organization Overview

The assessed organization is a **simulated mid-sized university environment** that relies on information technology systems to support academic, administrative, and operational activities. The institution provides services to approximately **3,000 students and 200 staff members**, including faculty, administrative personnel, and IT support teams.

The university's IT infrastructure includes several critical systems that support daily operations. These systems include the **Student Information System (SIS)** used to store and manage student records, the **Learning Management System (LMS)** used for online learning and course management, and the university **email system**, which facilitates communication between students and staff. In addition, the organization operates a **financial management system**, campus-wide **WiFi network infrastructure**, and multiple **file storage servers** used for academic and administrative data.

Due to the large number of users and the presence of sensitive information within these systems, the organization faces several cybersecurity risks such as phishing attacks, malware infections, unauthorized system access, and potential data breaches.

To evaluate the organization's cybersecurity posture, this assessment applies the **National Institute of Standards and Technology Cybersecurity Framework**, which provides a structured approach for identifying cybersecurity risks, assessing security controls, and identifying areas for improvement.

Methodology

This cybersecurity assessment was conducted using the **National Institute of Standards and Technology Cybersecurity Framework (NIST CSF)** as the primary reference model. The framework provides a structured approach for evaluating cybersecurity capabilities through five core functions: Identify, Protect, Detect, Respond, and Recover.

The assessment process began with the identification of key organizational assets and information systems that support the university's operational activities. An asset inventory was developed to document critical infrastructure, applications, and data systems within the simulated environment.

Following asset identification, potential cybersecurity risks were evaluated through a structured risk assessment process. Each identified risk was analyzed based on its **likelihood of occurrence** and **potential impact** on organizational operations. Risk scores were calculated to determine the relative severity of each risk and to support prioritization.

The assessment also included a review of existing security controls and a gap analysis comparing current practices with recommended controls within the NIST Cybersecurity Framework. Finally, a cybersecurity maturity assessment was performed to evaluate the organization's overall security capability and identify areas for improvement.

Asset Inventory

An asset inventory was developed to identify the key systems, infrastructure components, and data resources that support the organization's operational activities. Asset identification is a critical component of cybersecurity risk management, as it allows organizations to understand which systems require protection and where potential vulnerabilities may exist.

The inventory includes a range of information assets such as enterprise applications, network infrastructure, endpoint devices, and data storage systems. Key assets identified during the assessment include the Student Information System, Learning Management System, email services, financial management systems, campus network infrastructure, file storage servers, and authentication services.

Each asset was documented along with relevant attributes such as asset type, ownership, location, data classification, and criticality level. These attributes help determine the relative importance of each asset and support the prioritization of cybersecurity protections.

ASSET INVENTRY							
Asset ID	**Asset Name**	**Asset Type**	**Owner**	**Location**	**Data Classification**	**Criticality**	**Notes**
A-01	Student Information System	Application	IT Department	Data Center	Confidential	Critical	Stores student personal records
A-02	University Email System	Cloud Services	IT Department	Microsoft 365	Internal	High	Staff and student communication
A-03	Learning Management System (LMS)	Web Application	IT Department	Cloud	Internal	High	Online learning platform
A-04	Finance Management System	Application	Finance Department	Data Center	Confidential	Critical	Financial records
A-05	Campus Wifi Network	Network Infrastructure	Network Team	Campus Wide	Internal	High	Supports ~3000 users
A-06	Faculty File Server	File Storage	IT Department	Data Center	Confidential	High	Academic documents
A-07	University Website	Web Server	IT Department	Cloud Hosting	Public	Medium	Public university information
A-08	Student Desktop Computers	Endpoint Devices	Students	Campus	Internal	Medium	Access to university systems
A-09	Staff Desktop Computers	Endpoint Devices	IT Department	Offices	Internal	High	Used for admin work
A-10	Identity & Authentication Server	Authetication	IT Security	Data Center	Confidential	Critical	Manages user logins
A-11	Backup Storage System	Storage	IT Department	Data Center	Confidential	Critical	Disaster recovery backups
A-12	Network Firewall	Security Device	Network Team	Data Center	Internal	Critical	Protects network perimeter

Risk Register

A structured risk assessment was conducted to identify potential cybersecurity threats that could impact the organization's critical assets. The objective of the assessment was to evaluate potential threats, determine their likelihood of occurrence, and assess their potential impact on the organization's operations.

Each identified risk was analyzed using a qualitative risk scoring model based on two primary factors: likelihood and impact. Likelihood represents the probability that a particular threat may occur, while impact reflects the potential damage or disruption that could result if the threat were successfully realized.

A numerical scoring approach was used to calculate the risk score by multiplying likelihood and impact values. This approach allows risks to be categorized into different severity levels, including low, medium, high, and critical.

The risk assessment identified several key threats affecting the organization's systems, including phishing attacks targeting email systems, ransomware infections on file storage servers, unauthorized access to sensitive databases, and distributed denial-of-service (DDoS) attacks affecting publicly accessible services.

RISK REGISTER

Risk ID	Asset	Risk Description	Threat	Vulnerability	Likelihood (1-3)	Impact (1-3)	Risk Score	Risk Level	Owner	Mitigation
R-01	University Email System	Phishing attack targeting staff	Social engineering	Lack of security awareness	3	3	9	Critical	IT Security	Implement awareness training
R-02	Student Information System	Unauthorized access to student records	Insider threat	Weak access controls	2	3	6	High	IT Security	Implement RBAC (Role-Based Access Control)
R-03	University Website	Website downtime due to DDoS	Botnet attack	No traffic filtering	2	2	4	Medium	Network Team	Deploy Web Applicatoin Firewall
R-04	Faculty File Server	Ransomware infection	Malware	No endpoint detection	2	3	6	High	IT Security	Deploy Endpoint Detection and Response
R-05	Campus Wifi Network	Unauthorized network access	Rogue Devices	Weak network authentication	2	2	4	Medium	Network Team	Implement WPA3
R-06	Staff Desktop Computers	Malware infection	Malicious downloads	Outdated antivirus	2	2	4	Medium	IT Department	Update antivirus
R-07	Identity & Authentication Server	Credential theft	Brute force attack	No multi-fator authentication	3	3	9	Critical	IT Security	Implemenet Multi-factor authentication
R-08	Backup Storage System	Backup failure	Hardware failure	No redundancy	2	3	6	High	IT Department	Implement redundant backups
R-09	Learning Management System (LMS)	Data leakage	Misconfiguration	Weak access policies	2	2	4	Medium	IT Department	Configure access control
R-10	Finance Management System	Financial data breach	Insider misuse	Poor monitoring	2	3	6	High	Finance Department	Enable logging
R-11	Student Desktops Computers	Compromised endpoints	Malware	Unmanaged devices	2	2	4	Medium	IT Security	Implement device policies
R-12	Network Firewall	Security misconfiguration	Human error	Lack of review process	1	3	3	Medium	Network Team	Regular configuration audits

Risk Heat Map

The risk heat map provides a visual representation of the organization's cybersecurity risk landscape by mapping identified risks according to their assessed likelihood and potential impact. This visualization helps highlight which areas of risk require the most immediate attention and supports effective prioritization of mitigation efforts.

The analysis shows that a small number of risks fall within the **high-risk zone**, indicating scenarios where both the probability of occurrence and potential organizational impact are significant. These risks represent the most critical threats to the organization and require prompt remediation and stronger security controls.

A larger portion of the identified risks are positioned within the **medium to medium-high risk areas** of the heat map. These risks indicate potential vulnerabilities that could affect operations if left unaddressed, though their likelihood or impact is comparatively lower than the most critical risks. These should be managed through planned risk mitigation strategies and improvements to existing security controls.

Overall, the heat map indicates that while the organization does not face a large concentration of extreme risks, several moderate to high-level risks are present and should be addressed to improve the organization's overall cybersecurity posture.

RISK HEAT MAP			
Impact/Likelihood	1	2	3
1			
2		R-03, R-05, R-06, R-09, R-11	
3	R-12	R-02, R-04, R-08, R-10	R-01, R-07

Security Control Inventory

A review of the organization's existing cybersecurity controls was conducted to evaluate the effectiveness of current security practices and determine whether adequate safeguards are in place to protect critical systems.

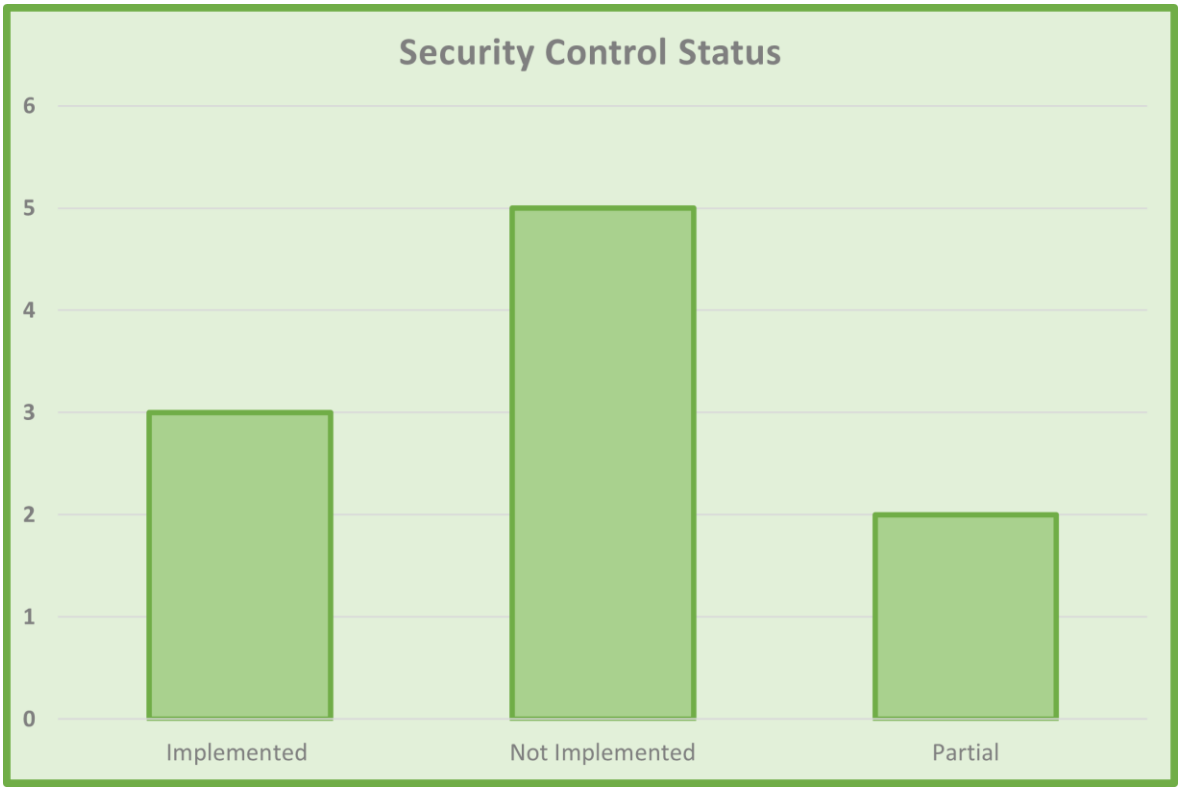
The analysis revealed that several foundational security controls have been implemented within the organization's IT environment. These include network firewalls for perimeter protection, antivirus solutions for endpoint devices, and basic system logging capabilities on selected servers.

However, the assessment also identified several important control gaps. Advanced security measures such as multi-factor authentication, centralized security monitoring, and intrusion detection systems are either partially implemented or absent from the current environment.

Additionally, the organization lacks a formal security awareness training program for users, which increases the risk of successful phishing attacks and other social engineering threats.

Understanding the current state of implemented security controls provides important insight into the organization's defensive capabilities and helps guide the identification of areas where additional security measures are required.

SECURITY CONTROL INVENTRY				
Control Catergory	**Control**	**Status**	**Effectiveness**	**Notes**
Network Security	Firewall	Implemented	High	Protects network perimeter
Endpoint Security	Antivirus	Implemented	Medium	Needs frequent updates
Idenetity Management	Multi-Factor Authentication	Not Implemented	Low	Major gap
Logging	System Logging	Partial	Medium	Only critical servers logged
Monitoring	SIEM	Not Implemented	Low	No centralized monitoring
Network Monitoring	IDS/IPS	Not Implemented	Low	No intrusion detection
Backup	Data Backup	Implemented	Medium	Weekly backup only
Access Control	Role-Based Access Control	Partial	Medium	Some systems enforced
Security Awareness	User Training	Not Implemented	Low	Users vulnerable to phishing
Incident Management	Incident Response Plan	Not Implemented	Low	No formal IR process


Security Control Status
6
5
4
3
2
1
0
Implemented
Not Implemented
Partial

NIST CSF Gap Analysis

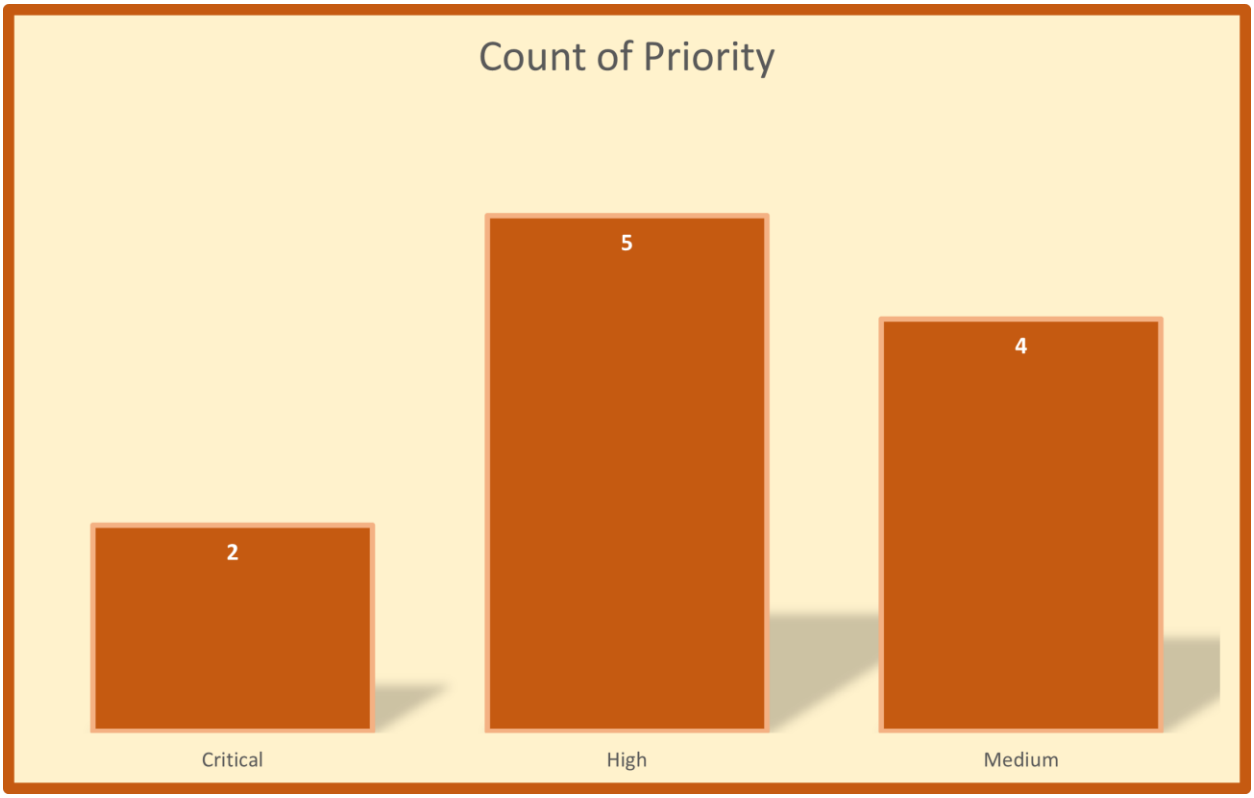
A gap analysis was conducted to compare the organization's current cybersecurity practices with the recommended practices defined in the **NIST Cybersecurity Framework**. This analysis focuses on the five core functions of the framework: Identify, Protect, Detect, Respond, and Recover.

The analysis revealed that the organization demonstrates partial implementation of several foundational cybersecurity practices, particularly within the Identify and Protect functions. Asset management activities and basic protective technologies such as firewalls and antivirus software are currently in place.

However, significant gaps were identified within the Detect and Respond functions. The organization currently lacks centralized security monitoring capabilities and does not maintain a formal incident response plan to manage cybersecurity incidents effectively.

These gaps highlight areas where improvements are required to strengthen the organization's ability to detect, respond to, and recover from cybersecurity incidents.

NIST CSF GAP ANALYSIS						
CSF Function	**Catergory**	**Current State**	**Target State**	**Gap**	**Priority**	**Recommendation**
Identify	Asset Management	Partial asset tracking	Complete asset inventry	Missing asset visibility	High	Implement asset management system
Identify	Risk Management	Informational risk handling	Formal risk program	No structured risk process	High	Establish risk register
Protect	Access Control	Password authentication	Multi-factor authentication	No MFA deployed	Critical	Deploy MFA
Protect	Security Awareness	No training	Annual awareness training	Staff unaware of threats	High	Launch training program
Protect	Data Protection	Limited encryption	Encryption for sensitive data	weak encryption practices	Medium	Implement encryption
Detect	Security Monitoring	Basic log collection	Centralized monitoring	No SIEM system	High	Deploy SIEM
Detect	Threat Detection	Reactive detection	Proactive threat monitoring	Limited detection capability	Medium	Implement Intrusion Detection System (IDS)
Respond	Incident Response	No formal procedures	Documented IR plan	Missing response framework	Critical	Create incident response plan
Respond	Communication	Informal communication	Defined escalation process	No defined reporting	Medium	Define IR communication flow
Recover	Backup Strategy	Weekly manual backups	Automated backups	Backup delays	Medium	Implement automated backup
Recover	Disaster Recovery	No DR plan	Tested DR strategy	No recovery testing	High	Develop DR plan


Count of Priority
2
5
4
Critical
High
Medium

Cybersecurity Maturity Assessment

A cybersecurity maturity assessment was conducted to evaluate the organization's overall security capability across the five functions defined by the NIST Cybersecurity Framework. Each function was assigned a maturity score ranging from Level 1 (Initial) to Level 5 (Optimized).

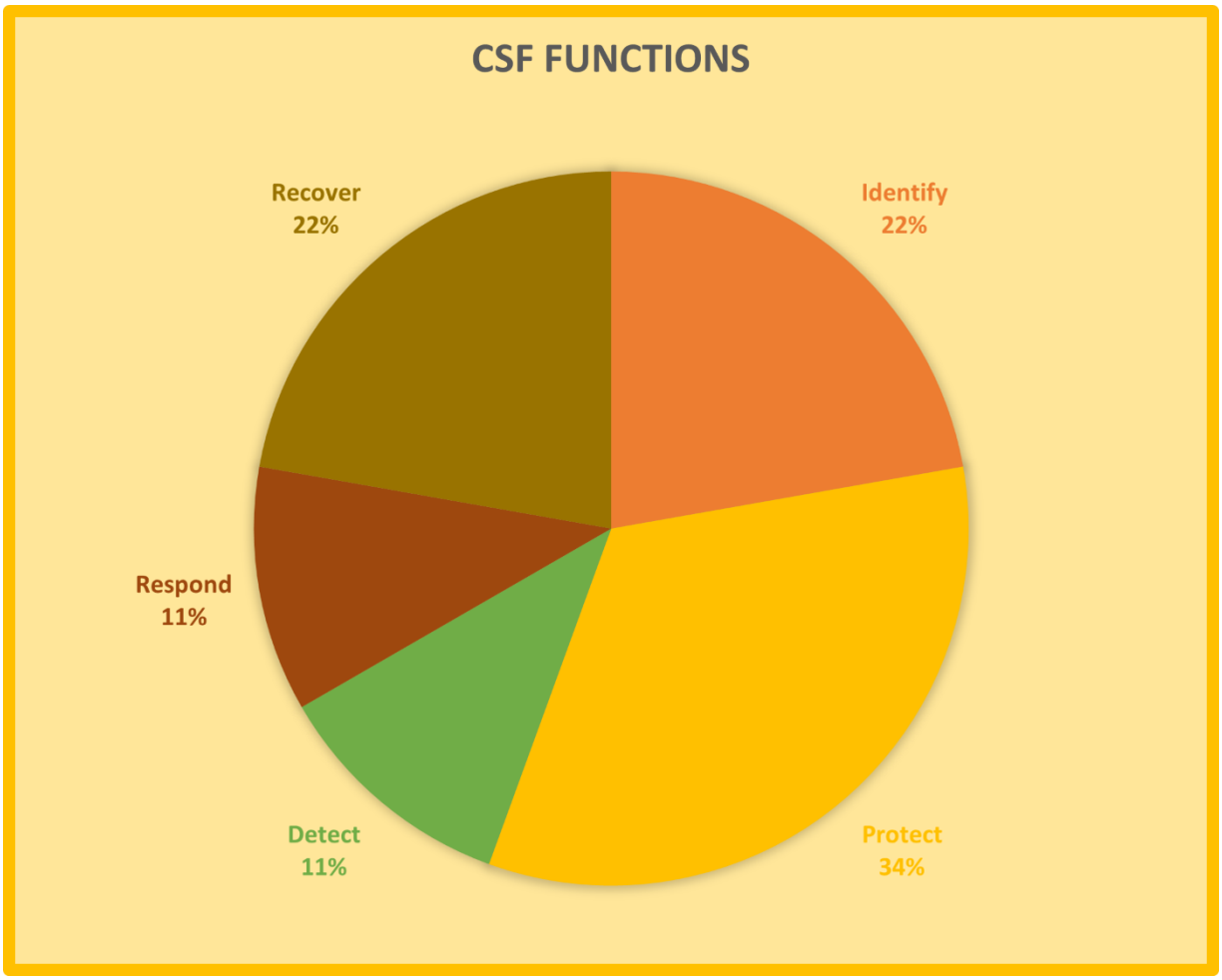
The assessment indicates that the organization currently operates at an early stage of cybersecurity maturity. The overall maturity score for the environment was calculated to be approximately **1.8 out of 5**, indicating that cybersecurity processes are largely informal and partially implemented.

The Protect function demonstrated the highest level of maturity due to the presence of foundational security technologies such as firewalls and endpoint protection systems. In contrast, the Detect and Respond functions received the lowest maturity scores due to the absence of centralized monitoring tools and formal incident response procedures.

The Recover function also demonstrated limited maturity due to the lack of a fully documented and tested disaster recovery strategy.

Improving these areas will significantly enhance the organization's resilience against cybersecurity threats and improve its alignment with the NIST Cybersecurity Framework.

Cybersecurity Matuarity Assessment		
CSF Function	**Score (1-5)**	**Explanation**
Identify	2	Some assets identified but no formal risk program
Protect	3	Basic Protections like firewall and antivirus exist
Detect	1	Limited monitoring capabilities
Respond	1	No formal incident response process
Recover	2	Backups exist but no disaster recovery planning


CSF FUNCTIONS
Recover
22%
Identify
22%
Respond
11%
Detect
11%
Protect
34%

Recommendations

Based on the findings of the risk assessment, gap analysis, and maturity evaluation, several recommendations are proposed to improve the organization's cybersecurity posture.

Priority should be given to implementing **multi-factor authentication (MFA)** across critical systems to reduce the risk of credential theft and unauthorized access. Additionally, the organization should establish a formal **incident response plan** that defines procedures for detecting, managing, and recovering from cybersecurity incidents.

The deployment of centralized **security monitoring capabilities**, such as a Security Information and Event Management (SIEM) system, would significantly improve the organization's ability to detect suspicious activities and respond to potential threats.

User-focused security improvements are also recommended. Implementing regular **security awareness training programs** can help reduce the likelihood of phishing attacks and other social engineering threats.

Finally, the organization should strengthen its **backup and disaster recovery processes** by implementing automated backup systems and conducting periodic recovery testing to ensure operational resilience during system failures or security incidents.

Conclusion

This cybersecurity assessment identified several risks and security gaps within the organization's IT environment. While the organization has implemented certain foundational security controls, additional improvements are required to enhance its ability to detect, respond to, and recover from cybersecurity threats.

The results of the risk assessment highlighted phishing attacks, credential theft, and ransomware infections as the most significant threats to the organization's systems. The gap analysis further revealed that security monitoring capabilities, incident response planning, and disaster recovery processes are areas requiring significant improvement.

The overall cybersecurity maturity score of approximately **1.8 out of 5** indicates that the organization is still in the early stages of developing a mature cybersecurity program.

By implementing the recommendations outlined in this report, the organization can significantly strengthen its cybersecurity posture, reduce its exposure to cyber threats, and improve its alignment with the NIST Cybersecurity Framework.